

Security+ 2.4 · An Overview of Malware

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.4 — An Overview of Malware**
(6:06) · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Malware = software malicioso. Categoriza: INTENÇÃO (spionagem, roubo, derrubar — DoS); FORMA (virus/worm/rootkit/trojan/keylogger/ransomware/stealer); ESCONDER (packer/compress/packing, polymorphic, metamorphic, fileless).

Highlights que a prova cobra

- Fileless = roda na memória, não toca em disco — invisível pro AV
- Polymorphic/métamorphobic muda de forma — evita assinatura

Dicas de prova & Cenários Típicos

- 'malware without a file on disk' = fileless malware

Cenário clássico de exame: Cenário: 'malware rodando sem arquivo no disco' = fileless malware.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.4 — An Overview of Malware)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **WORM:** Write Once, Read Many: Tecnologia de armazenamento imutável que permite gravar dados uma única vez e impede qualquer modificação ou exclusão durante o período de retenção (essencial para logs e conformidade).

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Malware que criptografa teus arquivos e exige pagamento pra devolver é:

- A) Spyware
- B) Ransomware
- C) Rootkit
- D) Worm

2. Qual tipo de malware se espalha automaticamente por redes sem necessidade de arquivo hospedeiro ou interação do usuário?

- A) Worm
- B) Trojan
- C) Spyware
- D) Adware

3. Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:

- A)** Escalada de privilégio (privilege escalation)
- B)** Negação de serviço
- C)** Engenharia social
- D)** Sniffing

4. O framework NIST CSF organiza a segurança em 5 funções. Quais são?

- A)** Instalar, Atualizar, Testar, Auditar, Arquivar
- B)** Identificar, Proteger, Detectar, Responder, Recuperar
- C)** Planejar, Fazer, Checar, Agir, Revisar
- D)** Prevenir, Punir, Prever, Provar, Publicar

5. Cenário corporativo (An Overview of Malware): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Fileless = roda na memória, não toca em disco — invisível pro AV'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Fileless = roda na memória, não toca em disco — invisível pro AV...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (An Overview of Malware): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Polymorphic/métamorphobic muda de forma — evita assinatura'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Polymorphic/métamorphobic muda de forma — evita assinatura...

7. Cenário corporativo (An Overview of Malware): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'malware without a file on disk' = fileless malware'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'malware without a file on disk' = fileless malware...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (An Overview of Malware): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'malware rodando sem arquivo no disco' = fileless malware.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário: 'malware rodando sem arquivo no disco' = fileless malware....

9. Cenário corporativo (An Overview of Malware): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Fileless = roda na memória, não toca em disco — invisível pro AV'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Fileless = roda na memória, não toca em disco — invisível pro AV...

10. Cenário corporativo (An Overview of Malware): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Polymorphic/métamorphobic muda de forma — evita assinatura'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Polymorphic/métamorphobic muda de forma — evita assinatura...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Ransomware.

✓ **Por que está certa:** A alternativa correta é 'Ransomware'. Ransomware é um tipo de malware que criptografa os arquivos da vítima e exige o pagamento de um resgate (geralmente em criptomoedas) para fornecer a chave de descriptografia. O enunciado descreve exatamente esse comportamento: um malware que criptografa arquivos e exige pagamento para devolvê-los. A CompTIA classifica ransomware como uma ameaça crítica, frequentemente propagada por phishing, exploração de vulnerabilidades ou serviços de área de trabalho remota. Portanto, a opção 'Ransomware' é a definição precisa do ataque descrito.

✗ **Por que as outras estão erradas:**

- *Spyware*: Spyware é um software malicioso projetado para coletar informações do sistema infectado sem o consentimento do usuário, como hábitos de navegação, credenciais, dados bancários, etc. Ele não criptografa arquivos nem exige resgate. Sua principal função é espionar e exfiltrar dados. No cenário, o objetivo é extorquir dinheiro por meio da criptografia de arquivos, o que não é característica do spyware. Portanto, spyware não se aplica.
- *Rootkit*: Rootkit é um conjunto de ferramentas maliciosas que permite ao atacante obter acesso privilegiado (root) e manter persistência no sistema, ocultando sua presença de mecanismos de detecção. Embora possa ser usado em conjunto com ransomware, o rootkit em si não criptografa arquivos nem exige pagamento. Sua finalidade é furtiva, não extorsiva. O enunciado descreve um ataque de extorsão financeira por criptografia, não a instalação de um rootkit. Logo, rootkit não é a resposta correta.
- *Worm*: Worm é um malware autorreplicante que se propaga automaticamente pela rede, explorando vulnerabilidades, sem necessariamente precisar de um arquivo hospedeiro ou interação do usuário. Embora worms possam transportar payloads como ransomware, eles não são definidos por criptografar arquivos e exigir resgate. O comportamento descrito no enunciado é específico de ransomware, não de worm. Portanto, worm é uma classificação incorreta para o ataque em questão.

2) A — Worm.

✓ **Por que está certa:** O Worm é um tipo de malware autônomo que se autorreplica e se espalha automaticamente por redes, explorando vulnerabilidades em serviços ou sistemas operacionais, sem necessidade de um arquivo hospedeiro ou de interação do usuário. Diferente de vírus, ele não precisa de um programa portador para se propagar. No CompTIA Security+ (domínio 2.4 - 'Given a scenario, analyze indicators of malicious activity'), o worm é classicamente definido como malware que se espalha sozinho pela rede, consumindo largura de banda e comprometendo sistemas em larga escala. É exatamente o que o enunciado descreve.

✗ **Por que as outras estão erradas:**

- *Trojan*: Um Trojan (cavalo de Troia) é um malware que se disfarça de software legítimo para enganar o usuário e ser executado. Ele depende da interação do usuário para infectar o sistema e não se autorreplica automaticamente pela rede. Portanto, não atende ao critério de 'espalhar-se automaticamente sem interação do usuário'.
- *Spyware*: O Spyware é um software malicioso projetado para coletar informações do usuário sem consentimento, como hábitos de navegação, credenciais e dados pessoais. Ele não se espalha automaticamente por redes; geralmente é instalado por meio de engenharia social ou bundled com outros softwares. Logo, não é a resposta correta.
- *Adware*: O Adware é um software que exibe anúncios indesejados e pode redirecionar o

navegador, mas não se autorreplica nem se espalha automaticamente por redes. Sua disseminação depende de instalação pelo usuário ou de outros malwares. Portanto, não atende ao enunciado.

3) A — Escalada de privilégio (privilege escalation).

✓ **Por que está certa:** A escalada de privilégio (privilege escalation) é a técnica na qual um atacante, após obter acesso inicial com um usuário comum, explora vulnerabilidades, falhas de configuração ou credenciais mal protegidas para elevar seu nível de permissão dentro do sistema. No contexto do CompTIA Security+ (SY0-701), esse conceito é classificado como uma tática de pós-exploração (TA0004 no MITRE ATT&CK) e pode ser vertical (de usuário comum para administrador) ou horizontal (de um usuário para outro com privilégios semelhantes). O enunciado descreve exatamente a transição de 'usuário comum' para 'Domain Admin', que é o exemplo clássico de escalada vertical de privilégios em ambientes Windows Active Directory. Portanto, a opção correta é a que identifica esse movimento como privilege escalation.

✗ Por que as outras estão erradas:

- *Negação de serviço:* Negação de serviço (DoS) é um ataque que visa tornar um recurso, serviço ou rede indisponível para usuários legítimos, geralmente por meio de sobrecarga de requisições, esgotamento de recursos ou exploração de falhas que causam travamento. No cenário descrito, o atacante não está tentando derrubar o serviço, mas sim obter mais poder dentro do domínio. A negação de serviço não envolve elevação de privilégios; ela afeta a disponibilidade, não a confidencialidade ou integridade das permissões. Portanto, não se aplica ao ganho de poder de usuário comum para Domain Admin.
- *Engenharia social:* Engenharia social é a manipulação psicológica de pessoas para que revelem informações confidenciais ou executem ações que comprometam a segurança, como clicar em links maliciosos ou fornecer credenciais. Embora a engenharia social possa ser um vetor inicial para obter acesso, ela não descreve o processo técnico de elevação de privilégios dentro do sistema. O enunciado foca no ganho de poder após o acesso, não no método de obtenção inicial. Portanto, engenharia social não é a classificação correta para a transformação de usuário comum em Domain Admin.
- *Sniffing:* Sniffing (ou eavesdropping) é a interceptação passiva de tráfego de rede para capturar dados sensíveis, como credenciais em texto claro ou informações de sessão. É uma técnica de coleta de informações, não de elevação de privilégios. Mesmo que o sniffing possa levar à obtenção de credenciais administrativas, ele não é o ato de escalar privilégios em si. O enunciado descreve o resultado final (tornar-se Domain Admin), não o método de captura de tráfego. Portanto, sniffing não é a resposta correta para classificar o ganho de poder.

4) B — Identificar, Proteger, Detectar, Responder, Recuperar.

✓ **Por que está certa:** O NIST Cybersecurity Framework (CSF) 2.0 organiza as atividades de segurança cibernética em cinco funções principais: Identificar, Proteger, Detectar, Responder e Recuperar. Essas funções representam o ciclo de vida completo da gestão de riscos cibernéticos. 'Identificar' envolve entender o contexto organizacional, ativos, riscos e vulnerabilidades. 'Proteger' abrange a implementação de salvaguardas para garantir a entrega de serviços críticos. 'Detectar' define as atividades para identificar a ocorrência de eventos de segurança cibernética. 'Responder' compreende as ações tomadas após a detecção de um incidente. 'Recuperar' foca na restauração de capacidades ou serviços que foram prejudicados. Essa estrutura é amplamente adotada e exigida no domínio de Arquitetura e Design de Segurança da certificação CompTIA Security+ (SY0-701), especificamente no objetivo 2.1, que trata de frameworks e diretrizes.

✗ Por que as outras estão erradas:

- *Instalar, Atualizar, Testar, Auditar, Arquivar:* Esses termos descrevem etapas genéricas de um processo operacional de TI, como um ciclo de vida de software ou de gestão de patches, mas não

constituem as funções do NIST CSF. 'Instalar' e 'Atualizar' referem-se à implantação e manutenção de sistemas; 'Testar' é uma atividade de verificação; 'Auditar' é uma avaliação de conformidade; e 'Arquivar' é uma prática de retenção de dados. Nenhuma dessas ações corresponde às funções estratégicas de alto nível definidas pelo NIST CSF, que são orientadas a riscos e não a tarefas táticas.

- *Planejar, Fazer, Checar, Agir, Revisar*: Essa é uma variação do ciclo PDCA (Plan-Do-Check-Act), utilizado em sistemas de gestão da qualidade e melhoria contínua, como a ISO 9001. Embora o NIST CSF possa ser integrado a processos de melhoria contínua, suas cinco funções não são 'Planejar, Fazer, Checar, Agir, Revisar'. O PDCA é um modelo genérico de gestão, enquanto as funções do CSF são específicas para segurança cibernética e possuem escopo e definições próprias. A inclusão de 'Revisar' como quinta etapa é uma distorção, pois o PDCA clássico tem quatro etapas.
- *Prevenir, Punir, Prever, Provar, Publicar*: Esses termos não fazem parte de nenhum framework reconhecido de segurança cibernética. 'Prevenir' é um objetivo, mas não uma função do CSF; 'Punir' é uma ação disciplinar ou legal, não uma função de segurança; 'Prever' é uma meta aspiracional, não uma função operacional; 'Provar' e 'Publicar' são ações de auditoria e comunicação, respectivamente, mas não compõem a estrutura do NIST CSF. Essa alternativa mistura conceitos de justiça, previsão e divulgação, sem qualquer relação com as funções oficiais do framework.

5) A — Implementar a solução correspondente: Fileless = roda na memória, não toca em disco — invisível pro AV....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (An Overview of Malware): Fileless = roda na memória, não toca em disco — invisível pro AV.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: Polymorphic/métamorphobic muda de forma — evita assinatura....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (An Overview of Malware): Polymorphic/métamorphobic muda de forma — evita assinatura.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: 'malware without a file on disk' = fileless malware....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (An Overview of Malware): 'malware without a file on disk' = fileless malware.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: Cenário: 'malware rodando sem arquivo no disco' = fileless malware.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (An Overview of Malware): Cenário: 'malware rodando sem arquivo no disco' = fileless malware..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: Fileless = roda na memória, não toca em disco — invisível pro AV....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (An Overview of Malware): Fileless = roda na memória, não toca em disco — invisível pro AV.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Polymorphic/métamorphobic muda de forma — evita assinatura....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (An Overview of Malware): Polymorphic/métamorphobic muda de forma — evita assinatura.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.